

ACTIVIDAD 01. ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

Caso: Aurora Market

Nombre: Dalia Montserrat Caballero Silva

Hacker Women Council · Ethical Hacking

Fecha: 3 de septiembre del 2026

1. Objetivo

Objetivo general. Realizar una evaluación de seguridad autorizada sobre la aplicación web de Aurora Market para determinar si existen vulnerabilidades que puedan permitir accesos indebidos a información de otros usuarios, afectar confidencialidad de datos personales o comprometer funciones sensibles de la plataforma.

Objetivos específicos

Comprobar separación entre cuentas: se verificará que un usuario autenticado solo pueda consultar y modificar los recursos que le corresponden, se enfocará en perfiles, direcciones, pedidos, historial de compras y cualquier función que utilice identificadores de usuario o de recursos, así se confirmará si el problema reportado puede reproducirse con cuentas de prueba y determinar si existe un riesgo real de exposición de datos entre clientes.

Identificar exposición de la aplicación: se analizarán los servicios web autorizados, tecnologías visibles, mecanismos de autenticación, la gestión de sesiones, los endpoints usados por la aplicación y funciones disponibles para cada tipo de usuario, así se podrá conocer qué información y servicios podrían ser observados o utilizados por un atacante y detectar controles de seguridad débiles antes de que puedan ser aprovechados de manera maliciosa.

Traducir hallazgos en riesgos: cada vulnerabilidad encontrada deberá relacionarse con su posible impacto sobre Aurora Market, se va a explicar qué podría ocurrir si fueran explotadas, qué datos o procesos se verían afectados y qué medidas deberían aplicarse para reducir el riesgo, no solo es entregar la lista de fallas.

2. Alcance

Si se evaluará:

- La aplicación web oficial de Aurora Market y sus funciones accesibles desde el navegador.
- Registro, inicio de sesión, cierre de sesión y recuperación de acceso.
- Gestión de perfil, direcciones, carrito, pedidos e historial de compras.
- Controles de autenticación, autorización y manejo de sesiones.
- Endpoints o API usados directamente por la aplicación web, siempre que formen parte del dominio o activos autorizados.
- Servicios HTTP/HTTPS asociados a la aplicación y host autorizado.

Fuera del alcance:

- Redes sociales de la empresa, cuentas de correo y equipos personales de empleados.
- Proveedores externos, pasarelas de pago y servicios de entrega que no pertenezcan a Aurora Market.

- Sistemas internos o infraestructura no incluidos expresamente en la autorización.
- Ataques de denegación de servicio, pruebas de estrés o acciones que puedan interrumpir la plataforma.
- Modificación, eliminación o extracción innecesaria de información real de clientes.

3. Autorización y condiciones

Permisos requeridos:

- Autorización escrita del propietario o responsable de Aurora Market.
- Dominio, URL, IP y activos exactos que podrán ser evaluados.
- Fecha y horario autorizado para las pruebas.
- Cuentas de prueba y roles disponibles.
- Permiso para usar herramientas de análisis e interceptación dentro del alcance acordado.
- Datos de contacto de un responsable técnico para atender incidentes durante la evaluación.
- Reglas para almacenar, proteger y eliminar las evidencias obtenidas.

Condiciones acordadas:

- Las pruebas se realizarán únicamente sobre activos autorizados, se usarán cuentas y datos de prueba siempre que sea posible.
- No se deberán realizar acciones que interrumpan deliberadamente el funcionamiento de la plataforma ni que alteren información real.
- Si durante una prueba se llegara a visualizar información de un cliente real, la actividad deberá detenerse en ese punto, conservar solo la evidencia mínima necesaria y notificar al responsable designado por Aurora Market.
- Todo hallazgo se manejará de forma confidencial.

4. Tipo de pentest

Gray-box. El escenario corresponde a un pentest Gray-box porque se dispone de información parcial sobre la plataforma, se sabe que existe una aplicación web, una base de datos, mecanismos de autenticación y distintos tipos de usuario, pero no se conoce por completo la arquitectura interna, el código fuente ni todas las configuraciones, eso permite simular la perspectiva de un usuario legítimo o de un atacante con cierto nivel de acceso, lo cual resulta especialmente adecuado para investigar el reporte de posible acceso a información de otra cuenta.

5. Planificación

Objetivos: identificar riesgos que puedan afectar la confidencialidad, integridad y disponibilidad de la información de Aurora Market, especialmente accesos no autorizados entre cuentas.

Alcance: evaluar únicamente la aplicación web autorizada, incluyendo autenticación, sesiones, perfiles, pedidos, carrito y endpoints relacionados.

Permisos y condiciones: contar con autorización formal, usar cuentas de prueba, respetar los activos definidos y evitar acciones que afecten datos reales o interrumpan el servicio.

Metodología a utilizar: utilizar PTES como metodología principal y OWASP WSTG como guía complementaria para las pruebas específicas de la aplicación web.

Recopilación de información previa: aplicar recopilación pasiva y activa controlada para identificar tecnologías, servicios, encabezados, endpoints y comportamiento de la aplicación.

Recursos necesarios: burp Suite, Nmap, navegador con DevTools, OWASP ZAP y al menos dos cuentas de prueba con diferentes usuarios/roles.

Programación del pentest: las pruebas serán realizadas el sábado de 02:00 a 04:00 am, que es un horario de baja actividad por ña hora, o un horario previamente confirmado por Aurora Market.

6. Fases del pentest

1) Reconocimiento

Se recopilará información sobre la aplicación autorizada para identificar su superficie de ataque: tecnologías visibles, certificados, encabezados, rutas, endpoints y servicios web, recopilación activa se limitará a activos establecidos en el alcance.

Comando Nmap 1: `nmap -sV -p 80,443,8080,8443 <IP_AUTORIZADA>`

Este comando permite comprobar si los puertos web indicados están abiertos e intentar identificar el servicio y la versión que responden en ellos y solo se utilizarían puertos relacionados con la aplicación web autorizada.

Comando Nmap 2: `nmap -Pn -p 80,443 <IP_AUTORIZADA>`

La opción -Pn permite continuar con la exploración de los puertos autorizados aunque el host no responda a las sondas de descubrimiento habituales, no se realizaría un barrido indiscriminado de toda la infraestructura si esa actividad no está expresamente autorizada.

2) Análisis de vulnerabilidades

Con Burp Suite se interceptará el tráfico HTTP/HTTPS generado al usar la aplicación con cuentas de prueba, se revisarán solicitudes y respuestas relacionadas con inicio de sesión, perfil, direcciones, carrito, pedidos, historial de compras, sesiones y funciones administrativas autorizadas y se van a observar métodos HTTP, cookies, tokens, parámetros, identificadores y respuestas del servidor para determinar cómo se aplican los controles de acceso.

3) Explotación

Las vulnerabilidades identificadas se validarían solo hasta obtener evidencia suficiente para demostrar su existencia e impacto, solo con cuentas y datos controlados, sin extraer información real ni alterar la operación normal.

4) Post-explotación

Si una vulnerabilidad permitiera obtener acceso adicional, se analizaría únicamente qué nivel de impacto podría alcanzar dentro de los activos autorizados, se van a documentar los permisos y recursos potencialmente afectados, sin realizar persistencia, movimiento lateral, exfiltración masiva ni modificación de datos reales.

5) Informe

Cada hallazgo incluirá descripción, evidencia, activo o función afectada, riesgo, posible impacto para Aurora Market, pasos de validación y recomendaciones de mitigación, las evidencias deberán ocultar datos personales y el informe puede dividirse en un resumen ejecutivo para la dirección y una sección técnica para el equipo de desarrollo.

7. Investigación: metodología elegida

Metodología elegida: PTES

PTES resulta adecuada para este proyecto porque organiza un pentest completo en etapas claras: pre-engagement, recopilación de inteligencia, modelado de amenazas, análisis de vulnerabilidades, explotación, post-explotación y reporte, pues eso obliga a definir primero el objetivo, el alcance, los permisos y las reglas antes de ejecutar herramientas, lo que coincide con las condiciones de Aurora Market.

En este caso, la metodología permite investigar de manera ordenada el posible problema de acceso entre cuentas, evaluar su impacto y documentar los resultados sin salir del alcance autorizado. OWASP WSTG complementa PTES porque proporciona una guía específica para probar aplicaciones web y revisar áreas como autenticación, autorización, sesiones y configuración.